

CUADERNILLO DE ESTUDIO

CLASE 7

“Seguridad en la nube”

☒ El tema más pedido por ustedes en la encuesta

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Eje: Extensión aplicada de la Unidad 2

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Negocio Digital (TP): _____

Fecha: _____

Índice

1. ¿Por qué esta clase es especial?	2
2. El modelo de responsabilidad compartida	3
2.1. La regla de oro	3
2.2. ¿Cómo se reparte según el tipo de servicio?	3
2.3. Los tres modelos de servicio	4
3. Riesgos típicos de mala configuración	5
3.1. Los 5 errores más frecuentes	5
3.2. Gestión de Identidades y Accesos (IAM)	5
4. Casos reales: cuando la nube se configura mal	6
5. Backups y continuidad en la nube	7
5.1. La regla 3-2-1 de backups	7
5.2. Conexión con el BIA (Clase 6)	7
6. Actividad práctica: análisis de caso y checklist	8
6.1. Parte 1: Análisis del caso real	8
6.2. Parte 2: Diseñar la checklist mínima de seguridad en la nube	9
7. Plantilla de checklist para tu TP Integrador	10
8. Glosario de la Clase 7	11
9. Espacio para notas y hallazgos	11

1. ¿Por qué esta clase es especial?

En la encuesta de expectativas, “**seguridad en la nube**” fue el tema más pedido fuera del programa original (8 menciones). Y no es casualidad: hoy, prácticamente **todo negocio digital nace en la nube**.

Concepto clave

[title=La realidad] Un e-commerce, una fintech o una app rara vez tienen servidores propios en un cuarto con aire acondicionado. Usan AWS, Azure, Google Cloud o servicios gestionados. Eso baja barreras de entrada y acelera el negocio. . . pero **no elimina la responsabilidad de proteger los datos**. Solo la cambia de lugar.

Esta clase es una **extensión aplicada de la Unidad 2** (Gestión de Riesgos). Todo lo que aprendimos —activos, amenazas, matriz $P \times I$, controles, BIA— se aplica igual en la nube. Lo que cambia es **dónde** termina tu responsabilidad y empieza la del proveedor.

Objetivos de esta clase:

1. Comprender el **modelo de responsabilidad compartida** en la nube.
2. Identificar **riesgos típicos de mala configuración** en servicios cloud usados por negocios digitales.

Entregable directo para tu TP: la actividad de hoy (la **checklist mínima de seguridad en la nube**) es el insumo del **Entregable 3** de tu Trabajo Práctico Integrador: “Evaluación de seguridad en la nube si el negocio opera sobre servicios cloud”. Lo que hagas hoy, lo reutilizás.

2. El modelo de responsabilidad compartida

Definición

El **modelo de responsabilidad compartida** establece que la seguridad en la nube es una tarea dividida: el **proveedor** (AWS, Azure, GCP) protege la infraestructura, y el **cliente** (tu negocio) protege lo que pone encima de esa infraestructura: sus datos, sus accesos y su configuración.

2.1 La regla de oro

Concepto clave

[title=“Seguridad DE la nube” vs “Seguridad EN la nube”]

- **Seguridad *DE* la nube (proveedor):** el hardware, los data centers, la red física, el hipervisor. Es responsabilidad del proveedor.
- **Seguridad *EN* la nube (cliente):** tus datos, tus identidades (IAM), la configuración de tus servicios, el cifrado de tu información. Es **tu** responsabilidad.

[title=El error más común] Muchos negocios asumen que “si está en AWS/Azure/Google, ya está seguro”. **Falso.** El proveedor garantiza que *su* infraestructura es segura; pero si vos dejás un bucket público o una contraseña débil, la brecha es **tuya**, no del proveedor.

2.2 ¿Cómo se reparte según el tipo de servicio?

La frontera de responsabilidad **se mueve** según el modelo de servicio contratado:

Capa de responsabilidad	IaaS	PaaS	SaaS
Infraestructura física	Proveedor	Proveedor	Proveedor
Red	Proveedor	Proveedor	Proveedor
Hipervisor	Proveedor	Proveedor	Proveedor
Sistema operativo	Cliente	Proveedor	Proveedor
Middleware / runtime	Cliente	Proveedor	Proveedor
Aplicación	Cliente	Cliente	Proveedor
Datos	Cliente	Cliente	Cliente
Identidades y accesos (IAM)	Cliente	Cliente	Cliente

Responsabilidad del proveedor

Responsabilidad del cliente

2.3 Los tres modelos de servicio

Modelo	¿Qué es?	Ejemplo
IaaS (Infraestructura como Servicio)	Te alquilan máquinas virtuales; vos gestionás el SO y todo lo de arriba.	AWS EC2, Azure VMs
PaaS (Plataforma como Servicio)	El proveedor gestiona SO y plataforma; vos solo subís tu aplicación y datos.	AWS Elastic Beanstalk, Azure App Service
SaaS (Software como Servicio)	Usás un software ya hecho; solo gestionás tus datos y accesos.	Gmail, Office 365, Slack

Concepto clave

[title=Lo que nunca cambia] Sin importar si usás IaaS, PaaS o SaaS, **los datos y las identidades (IAM) siempre son responsabilidad tuya**. Esa es la constante del modelo: mientras más “arriba” vas, el proveedor gestiona más cosas, pero **tu información y quién accede a ella siguen siendo tu problema**.

3. Riesgos típicos de mala configuración

La gran mayoría de las brechas en la nube **no son ataques sofisticados**; son errores de configuración evitables.

3.1 Los 5 errores más frecuentes

Error	¿Por qué es grave?
Buckets / almacenamiento público	Cualquiera en internet puede leer o descargar tus datos sin autenticarse.
IAM con permisos excesivos	Un empleado o servicio comprometido tiene acceso a mucho más de lo que necesita.
Claves de acceso (access keys) hardcodeadas	Claves de API escritas en el código o en repositorios públicos.
Sin MFA en cuentas administradoras	Basta una contraseña robada para tomar control de toda la cuenta cloud.
Sin backups (o sin probarlos)	Ante un ransomware o un borrado accidental, no hay forma de recuperar los datos.

3.2 Gestión de Identidades y Accesos (IAM)

Definición

IAM (Identity and Access Management) es el conjunto de políticas y herramientas que controla **quién** (identidad) puede hacer **qué** (permisos) sobre **qué recurso** en la nube.

Concepto clave

[title=El principio de menor privilegio] Cada usuario, servicio o aplicación debe tener **solo los permisos mínimos necesarios** para hacer su trabajo, y nada más. Si un componente es comprometido, el daño queda limitado a esos permisos mínimos, no a toda la cuenta.

4. Casos reales: cuando la nube se configura mal

[title=Caso 1: Capital One (2019) — 100 millones de registros] **Qué pasó:** Un atacante explotó una **mala configuración en el firewall de una aplicación web (WAF)** para acceder a un servidor en AWS. Desde ahí, aprovechó un **rol IAM con permisos excesivos** para leer buckets S3 con datos de aproximadamente **100 millones de solicitantes de tarjetas de crédito**.

Lecciones:

- Un solo punto mal configurado (el WAF) abrió la puerta.
- El **exceso de permisos IAM** amplificó el daño: el atacante accedió a mucho más de lo necesario.
- La brecha fue de **configuración y permisos**, no de la infraestructura de AWS.

[title=Caso 2: Buckets S3 públicos (patrón recurrente)] **Qué pasó:** En múltiples incidentes documentados (empresas de tecnología, consultoras y hasta organismos públicos), investigadores encontraron **buckets de almacenamiento S3 configurados como públicos**, exponiendo contraseñas, claves privadas, datos de clientes y documentos internos.

Lecciones:

- El almacenamiento en la nube **no es privado por defecto**; hay que configurarlo explícitamente.
- Un bucket mal configurado puede pasar **meses** expuesto antes de que alguien lo note.
- Falta de **monitoreo y alertas** que detecten configuraciones inseguras.

Concepto clave

[title=El patrón común] En ambos casos, el problema **no fue la nube en sí**, sino **cómo se configuró**. La nube es tan segura como la configuración que le pongas. Por eso la actividad de hoy es construir una **checklist** que prevenga exactamente estos errores.

5. Backups y continuidad en la nube

Definición

En la nube, el proveedor garantiza la **durabilidad de la infraestructura** (que los discos no fallen), pero **el backup de tus datos es tu responsabilidad**. Si borras un archivo por error o un ransomware lo cifra, el proveedor no lo recupera automáticamente.

5.1 La regla 3-2-1 de backups

Concepto clave

[title=Regla 3-2-1]

- **3** copias de tus datos (la original + 2 backups).
- **2** soportes o medios distintos.
- **1** copia fuera del sitio principal (en otra región o cuenta).

5.2 Conexión con el BIA (Clase 6)

Los backups en la nube se definen con los mismos conceptos del BIA:

- **RPO** (cuántos datos puedo perder) define **cada cuánto hago backup**.
- **RTO** (cuánto tardo en recuperar) define **qué tan rápido debo restaurar**.

[title=Ojo: un backup que no se prueba, no es un backup] De nada sirve tener backups si nunca verificaste que se puedan **restaurar**. Una buena práctica es hacer **simulacros periódicos de restauración** (lo que en la Unidad 4 veremos como parte de la continuidad de negocio).

6. Actividad práctica: análisis de caso y checklist

6.1 Parte 1: Análisis del caso real

[title=Analizando una brecha en la nube] Elijan uno de los casos de la Sección 5 (o el que proponga el docente) y respondan:

¿Cuál fue la vulnerabilidad principal (la mala configuración)?

¿Era responsabilidad del proveedor o del cliente? Justifiquen con el modelo de responsabilidad compartida.

¿Qué control concreto habría prevenido o mitigado la brecha?

¿Cómo lo ubicarían en la matriz $P \times I$ (probabilidad e impacto)?

6.2 Parte 2: Diseñar la checklist mínima de seguridad en la nube

[title=Construyendo la checklist para una pyme digital] En grupos, diseñen una **checklist mínima de seguridad en la nube de 5 a 8 puntos**, pensada para una pyme digital. Esta checklist es el **Entregable 3** de su TP Integrador.

Criterios:

- Cada punto debe ser **concreto y accionable** (no “ser seguros”, sino “habilitar MFA en cuentas admin”).
- Debe cubrir, como mínimo: **configuración, IAM, cifrado, backups y monitoreo**.
- Debe ser **realista** para una pyme (no exigir controles de una multinacional).

Concepto clave

[title=Ejemplo de checklist (para inspirarse, no copiar)]

1. Almacenamiento (buckets) **privado por defecto**; acceso público bloqueado a nivel de cuenta.
2. **MFA habilitado** en todas las cuentas root y administradoras.
3. IAM con **menor privilegio**; sin claves compartidas; rotación periódica de claves de acceso.
4. **Cifrado** de datos en reposo y en tránsito (TLS).
5. **Backups automáticos** con regla 3-2-1 y pruebas periódicas de restauración.
6. **Logging y monitoreo** habilitados, con alertas ante configuraciones inseguras.
7. **Parcheo** y actualización de sistemas operativos y servicios gestionados.

7. Plantilla de checklist para tu TP Integrador

Completá esta plantilla con la checklist de tu grupo. Es el borrador directo del **Entregable 3** del TP Integrador. Adapten cada punto al negocio digital que eligieron.

Negocio digital: _____

Proveedor/es cloud que usa (o usaría): _____

Modelo de servicio predominante (IaaS / PaaS / SaaS): _____

#	Control / punto de la checklist	¿Qué riesgo mitiga?
1		
2		
3		
4		
5		
6		
7		
8		

[title=Autoevaluación de la checklist]

¿Cubre configuración, IAM, cifrado, backups y monito

¿Es realista para el tamaño del negocio elegido? ¿Qué

8. Glosario de la Clase 7

Término	Definición en una línea
Nube (Cloud)	Servicios de cómputo bajo demanda a través de internet.
Responsabilidad compartida	División de tareas de seguridad entre proveedor y cliente.
IaaS	Infraestructura como Servicio (alquilás máquinas virtuales).
PaaS	Plataforma como Servicio (subís tu app; el proveedor gestiona la plataforma).
SaaS	Software como Servicio (usás un software ya hecho).
IAM	Gestión de Identidades y Accesos (quién puede hacer qué).
Menor privilegio	Dar solo los permisos mínimos necesarios.
Bucket	Contenedor de almacenamiento de objetos (ej. S3).
MFA	Autenticación multifactor.
Access key	Clave de acceso programático a la cuenta cloud.
Regla 3-2-1	3 copias, 2 medios, 1 fuera del sitio (buena práctica de backup).
WAF	Web Application Firewall (firewall de aplicación web).

9. Espacio para notas y hallazgos

Anotá aquí dudas sobre el modelo de responsabilidad compartida, ideas de controles para la checklist de tu TP, o hallazgos del análisis de caso.